

L2 - 11.1. Intro Cyber Threat

Task 1: Introduction

This room will introduce you to cyber threat intelligence (CTI) and various frameworks used to share intelligence. As security analysts, CTI is vital for investigating and reporting against adversary attacks with organisational stakeholders and external communities.

Task 2: Cyber Threat Intelligence

Cyber Threat Intelligence (CTI) can be defined as evidence-based knowledge about adversaries, including their indicators, tactics, motivations, and actionable advice against them. These can be utilised to protect critical assets and inform cyber security teams and management business decisions. It would be typical to use the terms "data", "information", and "intelligence" interchangeably. However, let us distinguish between them to understand better how CTI comes into play.

Data: Discrete indicators associated with an adversary, such as IP addresses, URLs or hashes.

Information: A combination of multiple data points that answer questions such as "How many times have employees accessed tryhackme.com within the month?"

Intelligence: The correlation of data and information to extract patterns of actions based on contextual analysis.

The primary goal of CTI is to understand the relationship between your operational environment and your adversary and how to defend your environment against any attacks. You would seek this goal by developing your cyber threat context by trying to answer the following questions:

- Who's attacking you?
- What are their motivations?
- What are their capabilities?
- What artefacts and indicators of compromise (IOCs) should you look out for?

Threat Intel is geared towards understanding the relationship between your operational environment and your adversary. With this in mind, we can break down threat intel into the following classifications:

- **Strategic Intel:** High-level intel that looks into the organisation's threat landscape and maps out the risk areas based on trends, patterns and emerging threats that may impact business decisions.
- **Technical Intel:** Looks into evidence and artefacts of attack used by an adversary. Incident Response teams can use this intel to create a baseline attack surface to analyse and develop defence mechanisms.
- **Tactical Intel:** Assesses adversaries' tactics, techniques, and procedures (TTPs). This intel can strengthen security controls and address vulnerabilities through real-time investigations.
- **Operational Intel:** Looks into an adversary's specific motives and intent to perform an attack. Security teams may use this intel to understand the critical assets available in the organisation (people, processes and technologies) that may be targeted.
- **Indicator of Compromise (IOC):** Evidence of a breach, such as a C2 address in the logs.
- **Indicator of Attack (IOA):** A malicious action, such as PowerShell launching an unknown service, is underway.
- **Tactics, Techniques, and Procedures (TTP):** An adversary's detailed methodologies expressed in MITRE ATT&CK IDs and descriptions.

2a. What does CTI stand for? Cyber Threat Intelligence

2b. IP addresses, Hashes and other threat artefacts would be found under which Threat Intelligence classification? technical intel

Task 3: CTI Lifecycle

Threat intel is obtained from a data-churning process that transforms raw data into contextualised and action-oriented insights geared towards triaging security incidents. The transformational process follows a six-phase cycle:

Direction: Information assets and business processes that require defending. Potential impact to be experienced on losing the assets or through process interruptions. Sources of data and intel to be used towards protection.

Collection: Once objectives have been defined, security analysts will gather the required data to address them. Analysts will do this by using commercial, private and open-source resources available.

Processing: Raw logs, vulnerability information, malware and network traffic usually come in different formats and may be disconnected when used to investigate an incident.

Analysis: Investigating a potential threat through uncovering indicators and attack patterns. Defining an action plan to avert an attack and defend the infrastructure.

Dissemination: Different organisational stakeholders will consume the intelligence in varying languages and formats.

Feedback: The final phase covers the most crucial part, as analysts rely on the responses provided by stakeholders to improve the threat intelligence process and implementation of security controls.

3a. At which phase of the CTI lifecycle is data converted into usable formats through sorting, organising, correlation and presentation? Processing

3b. During which phase do security analysts get the chance to define the questions to investigate incidents? Direction

Task 4: CTI Standards & Frameworks

Standards and frameworks provide structures to rationalise the distribution and use of threat intel across industries. They also allow for common terminology, which helps in collaboration and communication.

MITRE ATT&CK: The ATT&CK framework is a knowledge base of adversary behaviour, focusing on the indicators and tactics. Security analysts can use the information to be thorough while investigating and tracking adversarial behaviour.

STIX: We mentioned STIX previously as the structured schema for describing threat information.

TAXII: The Trusted Automated eXchange of Indicator Information is a set of secure APIs used to exchange threat intelligence in near real-time for detection, prevention, and mitigation of threats. It supports two sharing models: **Collection**, which ensures threat intel is collected and hosted by a producer, and **Channel**, which publishes threat intel to users from a central server.

- **CVE (Common Vulnerabilities and Exposures)** — provides a catalogue number for discovered vulnerabilities, e.g., *CVE2023-4863*.
- **CVSS (Common Vulnerability Scoring System)** — a 0–10 severity scale with temporal and environmental modifiers for vulnerabilities.
- **NVD (National Vulnerability Database)** — the canonical repository that links numbers to scores, exploits, and affected products.

Cyber Kill Chain: Developed by Lockheed Martin, the Cyber Kill Chain breaks down adversary actions into steps. This breakdown helps analysts and defenders identify which stage-specific activities occurred when investigating an attack. The phases defined are shown in the image below.

Technique	Purpose	Examples
Reconnaissance	Obtain information about the victim and the tactics used for the attack.	Harvesting emails, OSINT, and social media, network scans
Weaponisation	Malware is engineered based on the needs and intentions of the attack.	Exploit with a backdoor, a malicious Office document
Delivery	Covers how the malware would be delivered to the victim's system.	Email, weblinks, USB
Exploitation	Breach the victim's system vulnerabilities to execute code and create scheduled jobs to establish persistence.	EternalBlue, Zero-Logon, etc.
Installation	Install malware and other tools to gain access to the victim's system.	Password dumping, backdoors, and remote access trojans
Command & Control	Remotely control the compromised system, deliver additional malware, move across valuable assets and elevate privileges.	Empire, Cobalt Strike, etc.

Technique	Purpose	Examples
Actions on Objectives	Fulfil the intended goals for the attack: financial gain, corporate espionage, and data exfiltration.	Data encryption, ransomware, and public defacement

4a. What sharing models are supported by TAXII? Collection and channel

4b. When an adversary has obtained access to a network and is extracting data, what phase of the kill chain are they on? actions on objectives

Task 5: Practical Analysis

5a. What was the source email address?

Answer: vipivillain@badbank.com

5b. What was the name of the file downloaded?

Answer: flbpfuh.exe

5c. After building the threat profile, what message do you receive?

Answer: John Doe